مقيد

شركة القيروان لنظم المعلومات

ميثاق إدارة الأمن السيبراني وهيكلها التنظيمي

برنامج الالتزام بالضوابط الأساسية للأمن السيبراني · مرحلة الحوكمة

رقم الوثيقة	QIS-CHR-001
الإصدار	٠,٤ (مسودة)
التاريخ	١١ نوفمبر ٢٠٢٦م
التصنيف	مقيد
إشارة المشاركة	أخضر · TLP:GREEN

إعداد نايف السالم، قائد الحوكمة والمخاطر والالتزام

دراسة حالة افتراضية. شركة القيروان لنظم المعلومات (QIS) وموظفوها وعملاؤها جهات وشخصيات افتراضية أُعدّت لملف أعمال مهني، وأي تشابه مع جهة حقيقية غير مقصود. أما الجهات التنظيمية والأطر المذكورة فهي حقيقية. لغة الوثيقة. تصدر هذه الوثيقة باللغتين العربية والإنجليزية، وفي حال وجود تعارض بين النصين يُعتمد النص العربي.

ضبط الوثيقة

الدور	المسمى الوظيفي	الاسم	الحالة
المالك	قائد الحوكمة والمخاطر والالتزام	نايف السالم	مكتمل
المراجِع	الرئيس التنفيذي للتقنية	ريم العتيبي	قيد الانتظار
المصادِق	اللجنة الإشرافية للأمن السيبراني	—	قيد الانتظار
المعتمِد	الرئيس التنفيذي	فيصل الحربي	قيد الانتظار

سجل الإصدارات

الإصدار	التاريخ	المُعِدّ	التغيير
٠٫١	٥ نوفمبر ٢٠٢٦م	نايف السالم	المسودة الأولى للمراجعة
٠٫٢	٩ نوفمبر ٢٠٢٦م	نايف السالم	تسمية أعلى مستوى للمخاطر «كارثي» بدلاً من «حرج»
٠٫٣	١٠ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الهوية البصرية الجديدة وصفحة الغلاف، وتحسين قابلية القراءة، وإضافة وسوم أمن المعلومات (التصنيف، والعلامة المائية، وإشارة المشاركة وفق مستويات الهيئة الوطنية للأمن السيبراني)، واعتماد اسم الشركة «شركة القيروان لنظم المعلومات».
٠٫٤	١١ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الأرقام الهندية في جميع أرقام الوثيقة، وكتابة أرقام الضوابط بالترتيب المتبع في وثائق الهيئة الوطنية للأمن السيبراني، تيسيراً للبحث عنها في نصوص الهيئة.

دورة المراجعة: سنوياً، أو عند أي تغيير في الهيكل التنظيمي للشركة أو في متطلبات الجهات التنظيمية.

التصنيف وإشارة المشاركة

الوسم	المستوى	ما يعنيه
التصنيف	مقيد	يؤدي الإفصاح غير المصرح به إلى ضرر محدود، ويقتصر الاطلاع على من تحددهم الشركة.

الوسم	المستوى	ما يعنيه
إشارة المشاركة (TLP)	أخضر	مشاركة في نفس المجتمع، دون النشر العام.

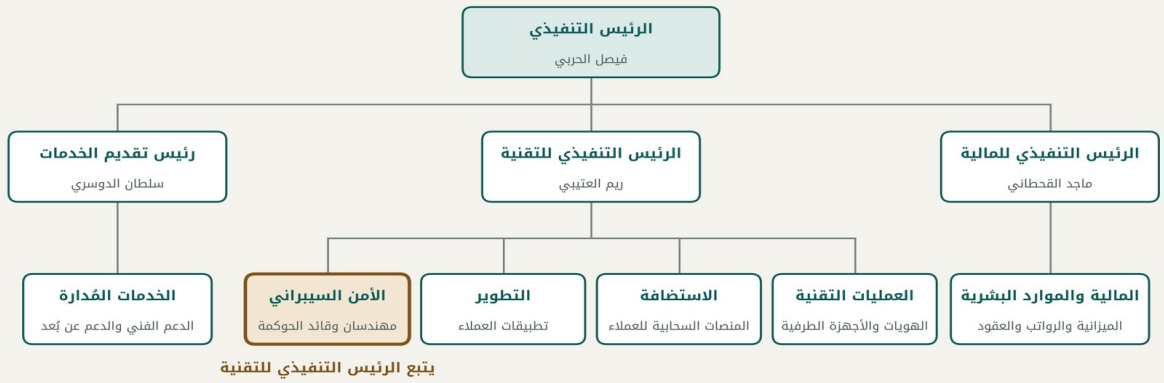
١. الغرض

ينشئ هذا الميثاق إدارة مستقلة للأمن السيبراني في شركة القيروان لنظم المعلومات، ويحدد تبعيتها وصلاحياتها ومسؤولياتها وعلاقتها بإدارة التقنية، وينظم عمل اللجنة الإشرافية للأمن السيبراني.

وهو يحقق الهدف الأول من أهداف البرنامج في QIS-PRF-001، ويعالج الخطر R-04 (تبعية الأمن السيبراني للرئيس التنفيذي للتقنية)، ويستجيب لمتطلبات المكوّنين الفرعيين ٢-١ (إدارة الأمن السيبراني) و٤-١ (الأدوار والمسؤوليات) في الضوابط الأساسية للأمن السيبراني.

٢. الوضع الحالي ومبررات التغيير

يتبع فريق الأمن السيبراني اليوم الرئيس التنفيذي للتقنية، المسؤول أيضاً عن تشغيل الأنظمة ومواعيد تسليم المشاريع. وينتج عن ذلك تعارض في المصالح: الجهة التي تنفذ التقنية هي نفسها التي تقيّم أمنها وتقرر أولوياته.

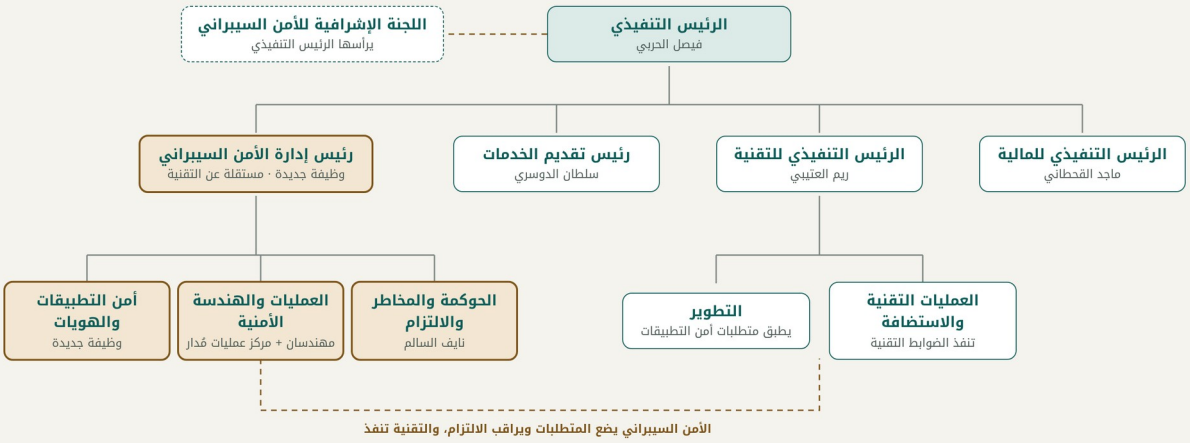


الشكل ١. الهيكل الحالي، أكتوبر ٢٠٢٦م

المشكلة	الأثر
تعارض المصالح	قد تُؤجَّل المعالجات الأمنية لصالح مواعيد التسليم دون علم الإدارة العليا.
غياب الرقابة المستقلة	لا تصل مخاطر الأمن السيبراني إلى الرئيس التنفيذي إلا عبر إدارة التقنية.
محدودية الصلاحيات	لا يملك الفريق صلاحية إيقاف تغيير يحمل خطراً كارثياً.

المشكلة	الأثر
عدم استيفاء متطلبات الضوابط	تتوقع الضوابط الأساسية أن تكون إدارة الأمن السيبراني مستقلة عن إدارة تقنية المعلومات وأن ترتبط برئيس الجهة.

٣. الهيكل المستهدف



الشكل ٢. الهيكل المستهدف بعد اعتماد الميثاق

الوحدة	الشاغل	المهام الرئيسة	مكوّنات ECC ذات العلاقة
رئاسة إدارة الأمن السيبراني	رئيس إدارة الأمن السيبراني (وظيفة جديدة)	قيادة الإدارة، وإعداد الاستراتيجية، والتقارير إلى الرئيس التنفيذي واللجنة الإشرافية	١-١، ٢-١
الحوكمة والمخاطر والالتزام	نايف السالم، قائد الحوكمة والمخاطر والالتزام	السياسات، وإدارة المخاطر، وتقييم الالتزام، ومخاطر الأطراف الخارجية، والتوعية، وحماية البيانات الشخصية	١-٣، ١-٥، ١-٧، ١-٨، ١-١٠، ٤-١
العمليات والهندسة الأمنية	مهندسا الأمن الحاليان، ومركز العمليات الأمنية المُدار	المراقبة، والاستجابة للحوادث، وإدارة الثغرات، وحماية الشبكات والأجهزة	٢-٣، ٢-٥، ٢-١٠، ٢-١٢، ٢-١٣
أمن التطبيقات والهويات	مهندس أمن تطبيقات (وظيفة جديدة)	متطلبات الأمن في التطوير، واختبار الاختراق، وإدارة الهويات والصلاحيات الهامة	١-٦، ٢-٢، ٢-١١، ٢-١٥

تُذكر أرقام المكوّنات الفرعية وفق الترقيم المعتمد في سجل المخاطر، ويُتحقق منها مقابل النص الرسمي للضوابط (ECC-2:2024) قبل الاعتماد.

٤. الميثاق

٤,١ التبعية والاستقلالية

- تتبع إدارة الأمن السيبراني الرئيس التنفيذي مباشرة، وتستقل تنظيمياً عن إدارة التقنية.
- يُعيَّن رئيس الإدارة بقرار من الرئيس التنفيذي، ولا يُعفى إلا بقرار منه بعد إبلاغ اللجنة الإشرافية.
- يُشغل منصب رئيس الإدارة والوظائف الإشرافية فيها بمواطنين سعوديين متفرغين ذوي خبرة في الأمن السيبراني، وفق ما تشترطه الضوابط الأساسية.
- تُخصص للإدارة ميزانية مستقلة يعتمدها الرئيس التنفيذي سنوياً.

٤,٢ الصلاحيات

- الاطلاع على جميع الأنظمة والسجلات والوثائق ذات العلاقة بالأمن السيبراني في الشركة، وفي حدود العقود لدى العملاء.
- طلب إيقاف أي تغيير أو إطلاق يحمل خطراً كارثياً وفق منهجية إدارة المخاطر، ويُرفع الخلاف إلى الرئيس التنفيذي للبت فيه خلال ٤٨ ساعة.
- إصدار المعايير والإجراءات الأمنية التفصيلية في إطار السياسات المعتمدة.
- التواصل المباشر مع الرئيس التنفيذي واللجنة الإشرافية، ومع جهات الاتصال الأمنية لدى العملاء.

٤,٣ المسؤوليات

- إعداد استراتيجية الأمن السيبراني وخارطة الطريق ومتابعة تنفيذها.
- إعداد السياسات ومراجعتها، ومتابعة الالتزام بها.
- إدارة مخاطر الأمن السيبراني وفق QIS-RMM-001، وإدارة سجل المخاطر.
- قياس الالتزام بالضوابط الأساسية والمتطلبات التعاقدية، وإعداد حزم الأدلة للعملاء.
- قيادة الاستجابة للحوادث وفق QIS-IRP-001.
- تقديم التقارير الدورية إلى الرئيس التنفيذي واللجنة الإشرافية.

٤,٤ الفصل بين المهام

النشاط	إدارة الأمن السيبراني	إدارة التقنية	المراجع المستقل
وضع المتطلبات والمعايير الأمنية	مسؤولة	تُستشار	—
تنفيذ الضوابط التقنية وتشغيلها	تُستشار وتتحقق	مسؤولة	—

النشاط	إدارة الأمن السيبراني	إدارة التقنية	المراجع المستقل
قياس الالتزام والفاعلية	مسؤولة	تقدم الأدلة	—
المراجعة المستقلة للأمن السيبراني	تُبلَّغ	تُبلَّغ	مسؤول
قبول المخاطر	توصي	تُستشار	—

لا تراجع إدارة الأمن السيبراني عملها بنفسها؛ إذ يكلف الرئيس التنفيذي مراجعاً مستقلاً بمراجعة الأمن السيبراني سنوياً.

٥. اللجنة الإشرافية للأمن السيبراني

البند	التفاصيل
الرئيس	الرئيس التنفيذي.
الأعضاء	الرئيس التنفيذي للتقنية، والرئيس التنفيذي للمالية، ورئيس تقديم الخدمات، ورئيس إدارة الأمن السيبراني (أميناً للجنة).
المهام	اعتماد الاستراتيجية والسياسات ورفعها للاعتماد، ومتابعة ملف المخاطر ومؤشرات الأداء والمخاطر، واعتماد خطط المعالجة وتمويلها، وقبول المخاطر المرتفعة.
الاجتماعات	شهرياً خلال برنامج الالتزام حتى أبريل ٢٠٢٧م، ثم ربع سنوياً، ويجوز عقد اجتماع طارئ عند حادثة حرجة.
النصاب	الرئيس وعضوان على الأقل، أحدهما رئيس إدارة الأمن السيبراني.
المحاضر	يوثقها أمين اللجنة، وتُحفظ دليلاً على الحوكمة.

٦. خطة الانتقال

#	الإجراء	المسؤول	الموعد المستهدف
١	اعتماد هذا الميثاق	الرئيس التنفيذي	نوفمبر ٢٠٢٦م
٢	نقل تبعية مهندسي الأمن وقائد الحوكمة إلى الرئيس التنفيذي، ويتولى قائد الحوكمة رئاسة الإدارة بالإنابة	الرئيس التنفيذي	ديسمبر ٢٠٢٦م
٣	عقد أول اجتماع للجنة الإشرافية وفق هذا الميثاق	الرئيس التنفيذي	ديسمبر ٢٠٢٦م
٤	التعاقد مع مركز عمليات أمنية مُدار (R-03)	رئيس الإدارة بالإنابة	فبراير ٢٠٢٧م

#	الإجراء	المسؤول	الموعد المستهدف
٥	تعيين رئيس إدارة الأمن السيبراني	الرئيس التنفيذي	مارس ٢٠٢٧م
٦	تعيين مهندس أمن التطبيقات والهويات	رئيس إدارة الأمن السيبراني	أبريل ٢٠٢٧م

٧. مؤشرات أداء الإدارة

مؤشرات الأداء (KPIs)

الرمز	المؤشر	المستهدف	التكرار
KPI-01	نسبة اجتماعات اللجنة الإشرافية المنعقدة وفق الجدول	١٠٠٪	ربع سنوي
KPI-02	نسبة السياسات المعتمدة السارية (غير المتجاوزة لموعد مراجعتها)	١٠٠٪	ربع سنوي
KPI-03	نسبة خطط معالجة المخاطر الكارثية والمرتفعة المنفذة في موعدها	٩٠٪ فأكثر	شهري

مؤشرات المخاطر (KRIs)

الرمز	المؤشر	العتبة	التكرار
KRI-01	عدد التغييرات ذات الخطر الكارثي التي نُفذت دون موافقة إدارة الأمن السيبراني	أخضر: ٠ أحمر: ١ فأكثر	شهري
KRI-02	عدد الوظائف الحرجة في الإدارة الشاغرة لأكثر من ٩٠ يوماً	أخضر: ٠ أصفر: ١ أحمر: ٢ فأكثر	ربع سنوي

٨. المراجع

المرجع	الجهة
الضوابط الأساسية للأمن السيبراني (ECC-2:2024)، المكوّنان الفرعيان ١-٢ و ١-٤	الهيئة الوطنية للأمن السيبراني
QIS-PRF-001 ملف الشركة ونطاق البرنامج	الشركة
QIS-RR-001 سجل المخاطر (R-04)	الشركة
QIS-RMM-001 منهجية إدارة المخاطر	الشركة